

BEFORE

- Legal/Privacy combined under LEGAL

AFTER

Roles & Responsibilities (RACI) — Third-Party Security Program

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.2

Effective date: _____

Review cadence: Every 12 months or upon material change

Legend: **R** = Responsible | **A** = Accountable | **C** = Consulted | **I** = Informed

1. Roles (generic titles)

- **Business Service Owner (BSO)** — accountable for the supplier relationship and residual risk acceptance for the service.
- **Third-Party Security Program Owner (TPSPO)** — accountable for program process, standards, and governance.
- **Security Engineering/Architecture (SEA)** — responsible for technical security review, baselines, integration patterns, and control validation.
- **Technology Risk (TR)** — consulted on risk posture, materiality, and risk acceptance where applicable.
- **Procurement (PROC)** — responsible for commercial process and supplier onboarding workflow.
- **Legal Counsel (LEGAL)** — responsible for contractual terms and legal obligations (non-privacy).
- **Data Protection Officer / Privacy Officer (DPO)** — responsible for privacy assessments, DPA terms, and privacy compliance oversight.

- **IT/Platform Owner (ITPO)** — responsible for implementing technical integrations and operational handover.
- **Service Management / Operations (OPS)** — responsible for operational readiness, monitoring handoff, and runbook alignment (where applicable).
- **Senior Residual Risk Acceptor (SRRA)** — accountable for residual risk acceptance for material Critical-tier exceptions/decisions (as defined in governance).

2. RACI by lifecycle activity

Activity	BSO	TPSPO	SEA	TR	PROC	LEGAL	DPO	ITPO	OPS	SRRA
Initiate supplier request / justify need	A/R	I	C	I	C	I	I	C	I	I
Complete intake & tiering worksheet	A/R	C	R	C	C	I	C	C	I	I
Confirm tier classification	A	A	R	C	I	I	I	C	I	I
Determine if personal data processing is in scope	A	I	C	I	C	I	A/R	C	I	I
Issue evidence pack to supplier	I	A	R	C	R	I	C	I	I	I
Review evidence & identify security gaps	I	C	A/R	C	I	I	C	C	C	I
Define minimum security requirements by tier	I	A	R	C	I	I	C	C	I	I
Select integration pattern / connectivity approach	I	C	A/R	C	I	I	C	R	C	I
Contract security schedule / security clauses	I	C	C	I	A/R	A/R	C	I	I	I
Privacy assessment (e.g., DPIA screening/assessment)	I	I	C	I	C	C	A/R	C	I	I
DPA terms and privacy contractual clauses	I	I	C	I	C	C	A/R	I	I	I

Activity	BSO	TPSPO	SEA	TR	PROC	LEGAL	DPO	ITPO	OPS	SRRA
Approve onboarding (Low/Important)	A	A	R	C	C	C	C	C	I	I
Approve onboarding (Critical)	A	A	R	C	C	C	C	C	I	C/A*
Implement technical controls (SSO, roles, logging, network rules)	I	I	C	I	I	I	I	A/R	R	I
Validate controls before go- live	I	C	A/R	C	I	I	C	R	C	I
Operational readiness / handover to run	I	I	C	I	I	I	I	R	A/R	I
Ongoing monitoring & trigger events review	I	A	R	C	C	C	C	C	R	I
Periodic re-assessment (by tier cadence)	I	A	R	C	R	C	C	C	C	I
Manage remediation actions (supplier)	A/R	C	R	C	C	I	I	C	I	I
Raise exception request	A/R	C	R	C	I	C	C	C	I	I
Approve exceptions (Low/Important)	A	A	R	C	I	C	C	C	I	I
Approve exceptions (Critical/material)	A	C	R	C	I	C	C	C	I	A/R
Offboarding (access removal, data return/deletion confirmation)	A	C	R	C	R	C	A/R (privacy)	A/R (access)	R	I
Audit / assurance support (evidence retrieval)	I	A	R	C	R	C	C	C	C	I

* SRRA approval is required only where defined by ``02-governance-approvals-escalation.md`` (e.g., material Critical-tier residual risk decisions).

3. Notes

- If personal data is processed, DPO involvement is mandatory for privacy assessment and DPA terms.
- Where a single individual holds multiple roles, approvals must still be recorded against the relevant role titles.